

AWS IAM ACCESS MANAGEMENT & GOVERNANCE LAB

End-to-end hands-on project report

RBAC • Least Privilege • MFA • Joiner / Mover / Leaver
AccessDenied Troubleshooting • Access Review • Audit
Evidence

Project scope

A manually implemented AWS IAM lab in a single account.
Includes documented tickets, permission tests, incident
investigation, governance findings, limitations and future
improvements.

Prepared as a portfolio-ready technical report. Replace this line with your name and date if desired.

Executive Summary

This project demonstrates how AWS Identity and Access Management (IAM) can be used to organize and review access in a small, single-account lab. Access is assigned primarily through groups and least-privilege policies. The lab includes MFA enforcement, Joiner/Mover/Leaver (JML) lifecycle tickets, temporary role-based S3 access, AccessDenied troubleshooting, and a documented access review.

The implementation and validation described here were performed manually through the AWS Management Console. A sample automation script was prepared but was not used to produce the reported results. The approvals and user scenarios are simulated, and the environment is not a production deployment.

Project at a glance

Item	Details
Environment	Single AWS account; IAM is global; test resources in eu-north-1
Identities	alice, bob, charlie, aws-suri
Groups	Finance-Group, Developer-Group, Support-Group, LabAdmins
Core controls	RBAC, custom least-privilege policies, MFA condition policy, password policy, temporary role access
Evidence tools	CloudTrail Event history, IAM Policy Simulator, IAM credential report, screenshots, ticket log
Tickets	IAM-001 through IAM-007; 3 lifecycle tickets, 3 access/role cases, 1 security-control ticket
Known open item	F-03: Charlie's disabled account remains pending deletion after the retention period

Main outcomes

- Completed and documented the Joiner, Mover and Leaver scenarios.
- Investigated and resolved three access-related cases: EC2 DescribeVolumes, role assumption, and S3 object-resource scope.
- Configured and tested MFA enforcement for the three department groups; the LabAdmins group was excluded from the RequireMFA attachment.
- The access review found a direct user policy and a missing RequireMFA attachment. Both were corrected; Charlie's account deletion remains pending.

Contents

- 1. Project Overview and Objectives
- 2. Problem Statement and Stakeholders
- 3. Solution and Deliverables
- 4. Environment and Tools
- 5. Architecture
- 6. End-State Access Model
- 7. Users, Groups and Policies
- 8. Least Privilege: Before and After
- 9. MFA and Password Policy
- 10. MFA Validation
- 11. Tickets and Lifecycle Workflow
- 12. IAM-001: Joiner
- 13. IAM-002: Mover
- 14. IAM-003: Leaver
- 15. IAM-004: EC2 AccessDenied
- 16. IAM-005: Temporary Role Access
- 17. IAM-006: S3 GetObject AccessDenied
- 18. IAM-007: MFA and Password Standards
- 19. Access Review and Findings
- 20. Benefits, Risks and Limitations
- 21. Lessons Learned
- 22. Results and Conclusion
- 23. Future Improvements
- 24. Cleanup Checklist
- 25. Interview Preparation

1. Project Overview and Objectives

Core idea

Build and validate an AWS IAM access-governance model in a single AWS account. The goal is to turn access management from an ad-hoc permission task into a controlled, reviewable process.

Objectives

- Use groups and role-based access control (RBAC) rather than unnecessary individual permissions.
- Apply least-privilege custom policies to department groups.
- Demonstrate Joiner / Mover / Leaver access lifecycle controls.
- Enforce and test an MFA condition policy and a lab password standard.
- Investigate IAM AccessDenied incidents using CloudTrail and IAM Policy Simulator.
- Provide temporary S3 access through an IAM role instead of permanent finance permissions.
- Perform an access review and document retain/remove decisions with evidence.

Scope

- In scope: IAM users, groups, custom policies, an IAM role, MFA, password policy, JML operations, permission troubleshooting, access review, credential report and documentation.
- Out of scope: production workloads, Active Directory, Microsoft Entra ID, SSO implementation, hands-on SailPoint, multi-account governance and implemented lifecycle automation.

Evidence principle: each major control should be supported by a console screenshot, test result, ticket or review record.

2. Problem Statement and Stakeholders

The project simulates organizational access-control failures that can occur when identity changes and permissions are not managed consistently.

Problem	Risk / effect
Unmanaged lifecycle	Users joining, changing departments or leaving may not receive, change or lose access correctly.
Excess permissions	Access can be broader than a user's job requires, violating least privilege.
No periodic review	Unnecessary or direct permissions may remain unnoticed.
AccessDenied incidents	A user lacks a needed permission; the cause must be found without granting excessive access.

Stakeholders

- Security and IT teams operate access controls and investigate incidents.
- Managers request or approve access based on business need.
- Auditors review evidence, decisions and control operation.
- An IAM analyst helps keep access accurate, timely and documented.

3. Solution and Deliverables

Design choice	Lab implementation
Group-based RBAC	4 IAM users and 4 groups; department access is assigned through group membership.
Least privilege	5 custom policies plus 1 IAM role; custom policies replace broad managed read-only policies for department groups.
MFA and password standard	RequireMFA condition policy on Finance-Group, Developer-Group and Support-Group; password policy configured at account level.
Lifecycle workflow	7 documented tickets from IAM-001 to IAM-007.
Troubleshooting	CloudTrail Event history and Policy Simulator used to investigate and validate access decisions.
Governance	Credential report and user Permissions tabs used for review; findings recorded with actions and status.

Important implementation boundary

All reported implementation and validation was manual through the AWS Console. The sample JML script was prepared but not used for these results. Automation is future scope.

4. Environment and Tools

Tool / service	Use in this lab
AWS IAM	Users, groups, roles, custom policies, MFA and password policy.
Amazon S3	Private bucket used for finance read-access tests.
Amazon EC2	View-only access tests; no EC2 servers were launched.
AWS CloudTrail	Event history used to investigate recorded API actions and AccessDenied events.
IAM Policy Simulator	Validated whether selected actions were allowed or denied under tested policy context.
IAM Credential Report	Supported access review of console access, MFA and access-key status.
Amazon CloudWatch	Read-only support-access scenario for Support-Group.
Authenticator app	MFA setup for console sign-in.
Ticket log and screenshots	Documented requests, investigations, fixes, verification and review evidence.

Environment details

- Single AWS account; IAM is global. Test resources were in eu-north-1.
- Users: alice, bob, charlie and aws-suri. Groups: Finance-Group, Developer-Group, Support-Group and LabAdmins.
- No compute servers were launched. The S3 bucket was used for limited read-access tests.
- IAM, MFA, CloudTrail Event history and Policy Simulator were used as lab controls; billing/free-tier status should be checked during cleanup.

5. Architecture

Access flow: identity → group or role → policy evaluation → AWS resource. Governance tools provide evidence and help investigate the decision; they are not themselves the permission path.

IDENTITIES	GROUPS / ROLE	POLICIES	RESOURCES
alice bob charlie aws-suri	Finance-Group Developer-Group Support-Group LabAdmins FinanceS3ReadRole	FinanceS3LabReadOnly DeveloperEC2LabReadOnly SupportCloudWatchLabRead Only RequireMFA AllowAssumeFinanceS3Read Role	S3 finance bucket EC2 console/API CloudWatch
GOVERNANCE / EVIDENCE CloudTrail Event history • Policy Simulator • Credential Report • Ticket log • Screenshots			

Temporary role path

Bob → Developer-Group → sts:AssumeRole permission → FinanceS3ReadRole (trust policy and role permissions) → finance S3 bucket. This gives temporary role-session access rather than a permanent finance permission attached to Bob.

Governance and evidence

CloudTrail Event history helps inspect recorded API events; Policy Simulator helps test selected policy decisions; the IAM credential report and Permissions tabs support review; tickets record the request, approval, action and verification.

6. End-State Access Model

Identity	End-state access / decision
alice	Member of Support-Group; CloudWatch read-only access; MFA requirement applies through the department group.
bob	Member of Developer-Group; EC2 read-only policy; MFA requirement applies through the department group; may assume FinanceS3ReadRole when permitted.
charlie	Offboarded: console access disabled, no group membership, no attached permissions, no active access keys found; account retained pending deletion after retention.
aws-suri	Member of LabAdmins with AdministratorAccess; standing admin access remains a known lab limitation.

Governance rule

Access should be explainable by role, limited to business need, reviewed periodically, and removable through a documented lifecycle process.

7. Users, Groups and Policies

Identities and group design

- alice: began without a group, joined Finance-Group, then moved to Support-Group.
- bob: Developer-Group; used for EC2 read-only tests, MFA testing and temporary role access.
- charlie: Support-Group before offboarding; later removed from the group and disabled.
- aws-suri: administrative lab identity in LabAdmins.

Policy inventory

Policy / role	Purpose
FinanceS3LabReadOnly	Read access to the test finance S3 bucket and its objects, as scoped in the policy.
DeveloperEC2LabReadOnly	Read-only EC2 actions required for the lab, including DescribeVolumes after troubleshooting.
SupportCloudWatchLabReadOnly	Read-only CloudWatch support scenario.
RequireMFA	Explicit-deny control when the request lacks MFA context, with an exception for MFA setup.
AllowAssumeFinanceS3ReadRole	Allows the Developer group to assume the specifically scoped finance-read role.
FinanceS3ReadRole	Temporary role with finance S3 read permissions and a trust policy.
AdministratorAccess	AWS-managed administrator policy attached to LabAdmins; standing admin access is a limitation.

8. Least Privilege: Before and After

Before

- AWS-managed read-only policies were initially attached to department groups.
- Broad service-level read-only access can expose more information than a particular job requires.

After

- Custom policies were created for the Finance, Developer and Support scenarios.
- Finance access was scoped to the test S3 bucket; Developer access was scoped to required EC2 read operations; Support access was scoped to CloudWatch read operations.
- Direct user policy attachments were avoided as the target design; the access review found and removed one leftover direct policy on Bob.

IAM evaluation reminder

AWS denies access by default unless an applicable policy allows it. An applicable explicit Deny overrides an Allow. Effective access depends on the policies and conditions that apply to the request.

9. MFA and Password Policy

MFA enforcement

- RequireMFA was attached to Finance-Group, Developer-Group and Support-Group; LabAdmins was excluded.
- The policy denies actions when MFA is absent, while allowing the required MFA setup actions.
- Bob was blocked without MFA and permitted for tested calls after MFA was enrolled.
- The access review found RequireMFA missing from Developer-Group; it was reattached. The original cause of the missing attachment was not identified.

Password policy used in the lab

- Minimum length: 12 characters.
- Complexity requirements enabled.
- Password expiration set to 90 days.
- Last five passwords blocked from reuse.
- Users allowed to change their own password.

These are the lab's configured settings, not a claim that AWS universally requires these exact values.

10. MFA Validation

Test	Observed result
Bob without MFA context	Blocked by the RequireMFA explicit Deny.
Bob with MFA enrolled	Tested EC2 calls were permitted when the necessary permissions were present.
Policy Simulator without MFA context	Denied when the RequireMFA condition applied.
Policy Simulator with aws:MultiFactorAuthPresent = true	Allowed for the tested action under that simulated context.

Troubleshooting note

A Policy Simulator test depends on the simulated request context. A result without the correct MFA condition context may differ from a real authenticated request. Use the simulator alongside actual sign-in tests and CloudTrail evidence, not as the only verification method.

11. Tickets and Lifecycle Workflow

Ticket	Type	User	Purpose	Status
IAM-001	Joiner	alice	Finance onboarding	Closed
IAM-002	Mover	alice	Finance to Support	Closed
IAM-003	Leaver	charlie	Offboarding	Closed
IAM-004	Incident	bob	EC2 DescribeVolumes denied	Closed
IAM-005	Role access	bob	Temporary finance bucket access	Closed
IAM-006	Incident	bob	S3 GetObject denied	Closed
IAM-007	Security	Lab users	MFA and password standards	Closed

Standard workflow

Request → Approval → Provisioning → Verification → Documentation → Periodic Review → Removal when no longer required.

Approvals and names in this project are simulated for lab documentation. They are not evidence of a real organization's approval process.

12. IAM-001 — Joiner: Finance Onboarding

Field	Details
Type	Joiner
User	alice
Requested by	Finance Manager (simulated)
Approved by	IAM Admin (simulated)
Date	05-Oct-2026
Status	Closed

Request / Issue

A new Finance user needs access to the finance bucket only.

Investigation

- Checked the baseline: Alice had no group membership and no policies.
- Added Alice to Finance-Group.

Root Cause

Alice had no group-based Finance permissions before the onboarding action.

Solution

Added Alice to Finance-Group, where the Finance S3 read-only policy was assigned.

Verification

Signed in with MFA; finance bucket read was allowed; EC2 access was denied as expected for her role.

Evidence to include

- Before/after group membership
- Finance bucket allowed test
- EC2 denied test

13. IAM-002 — Mover: Finance to Support

Field	Details
Type	Mover
User	alice
Requested by	Support Manager (simulated)
Approved by	IAM Admin (simulated)
Date	05-Oct-2026
Status	Closed

Request / Issue

Alice moves from Finance to Support and must not retain Finance access.

Investigation

- Confirmed Alice was initially a member of Finance-Group.
- Removed Finance-Group membership first, then added Support-Group.

Root Cause

The old Finance group membership would retain access inconsistent with Alice's new role if not removed.

Solution

Removed the old group first and added Support-Group; checked for direct policies and leftover access.

Verification

CloudWatch access worked; finance bucket access was denied; no Finance group permissions remained.

Evidence to include

- Support group membership
- CloudWatch allowed test
- Finance S3 denied test

14. IAM-003 — Leaver: Offboarding

Field	Details
Type	Leaver
User	charlie
Requested by	Support Manager (simulated)
Approved by	IAM Admin (simulated)
Date	06-Oct-2026
Status	Closed

Request / Issue

Charlie has left the organization; access must be removed promptly.

Investigation

- Disabled console access first.
- Removed the MFA device.
- Checked access keys; none existed.
- Removed Support-Group membership.

Root Cause

The account still existed, but access needed to be blocked and permissions removed.

Solution

Disabled console sign-in, removed group membership and MFA device, confirmed no active keys, and retained the account for the retention period.

Verification

Console access showed Disabled, the Permissions tab showed no policies, and a sign-in attempt failed. Account deletion remains pending after the retention period.

Evidence to include

- Console access disabled
- No group/policies
- Failed sign-in verification

15. IAM-004 — AccessDenied on EC2 Volumes

Field	Details
Type	Incident
User	bob
Reported by	Bob (self-reported)
Handled by	IAM Admin
Date	05-Oct-2026
Status	Closed

Request / Issue

Bob's EC2 dashboard showed AccessDenied on several tiles, including Volumes.

Investigation

- Checked Bob's Developer-Group membership and DeveloperEC2LabReadOnly policy.
- Filtered CloudTrail Event history for Bob and the denied API event.
- Tested the action in IAM Policy Simulator.

Root Cause

The `ec2:DescribeVolumes` action was missing from `DeveloperEC2LabReadOnly`, causing an implicit deny. Other service tiles outside the developer role remained denied by design.

Solution

Added `ec2:DescribeVolumes` to `DeveloperEC2LabReadOnly`, keeping the change scoped to the required read action.

Verification

The Volumes tile loaded. CloudTrail showed the denied call and the later successful call.

Evidence to include

- Dashboard before/after
- CloudTrail denied event
- Policy Simulator result

16. IAM-005 — Temporary Access Through a Role

Field	Details
Type	Role access
User	bob
Requested by	Finance Manager (simulated business approval)
Approved by	IAM Admin (simulated)
Date	06-Oct-2026
Status	Closed

Request / Issue

Bob needs temporary read access to the finance bucket without receiving a permanent Finance permission.

Investigation

- Created FinanceS3ReadRole with a trust policy for the AWS account and FinanceS3LabReadOnly role permissions.
- Bob's first Switch Role attempt failed.
- Checked CloudTrail and found an AssumeRole AccessDenied event.

Root Cause

Bob's identity-side policies lacked sts:AssumeRole permission. The role trust policy was already configured for the intended account.

Solution

Created AllowAssumeFinanceS3ReadRole, scoped to the role ARN, and attached it to Developer-Group.

Verification

Switch Role worked after signing in with MFA, and the role session reached S3. The role session is temporary.

Evidence to include

- Role trust and permissions
- Failed AssumeRole event
- Successful role switch

17. IAM-006 — S3 GetObject AccessDenied

Field	Details
Type	Incident
User	bob
Reported by	Bob (self-reported)
Handled by	IAM Admin
Date	06-Oct-2026
Status	Closed

Request / Issue

Inside the role session, Bob could not read the intended object in the finance bucket.

Investigation

- Reviewed the S3 error for the s3:GetObject action and object ARN.
- Checked FinanceS3LabReadOnly and found that the resource list referred to one specific object name.

Root Cause

The policy's object resource did not match the uploaded object name.

Solution

Changed the object resource to the bucket ARN followed by /*, allowing object reads within that one bucket. Upload and delete remained denied.

Verification

After switching to the role again, the test object opened successfully through the role.

Evidence to include

- GetObject error
- Corrected object resource
- Successful object read through role

18. IAM-007 — MFA and Password Standards

Field	Details
Type	Security control
Users	alice, bob, charlie
Requested by	IAM Admin
Approved by	IAM Admin (simulated)
Date	05-Oct-2026
Status	Closed

Request / Issue

Require MFA for department-group users and apply the lab's account password standard.

Investigation

- Created RequireMFA with an explicit Deny when MFA is absent, except for required MFA setup actions.
- Attached it to Finance-Group, Developer-Group and Support-Group, not LabAdmins.
- Configured the account password policy.
- An admin enrolled Bob's MFA because the policy exception prevented self-enrolment in the tested flow.

Root Cause

The control needed to deny normal actions without MFA while allowing the user to complete MFA setup.

Solution

Applied the policy and password settings. After the review found the attachment missing from Developer-Group, reattached it. The reason it went missing was not determined.

Verification

Bob was blocked without MFA and allowed after enrollment for tested calls. The simulator denied without MFA context and allowed with `aws:MultiFactorAuthPresent=true`.

Evidence to include

- RequireMFA policy
- Denied/allowed MFA tests
- Policy Simulator context results

19. Access Review and Findings

Review date: 06-Oct-2026. The review used the IAM credential report and each user's Permissions tab. Checks included group membership, direct policies, MFA, console access and access keys.

User	Groups	Direct policies	Console / MFA	Keys	Decision
alice	Support-Group	None	Enabled / MFA on	None found	Retain
bob	Developer-Group	One direct policy removed; none remaining in review	Enabled / MFA on	None found	Retain
charlie	None	None	Disabled / no MFA	None found	Remove; account deletion pending retention

Findings

ID	Finding	Risk	Action	Status
F-01	Bob had IAMUserChangePassword attached directly	Low: bypasses the group-based control design	Detached the direct policy	Closed
F-02	RequireMFA missing from Developer-Group	Medium: MFA policy not attached to the developer group	Reattached; original cause not traced	Closed
F-03	Charlie's disabled account still exists	Low; residual account lifecycle task	Delete after retention period	Open

Review outcome

The review identified a missing MFA-policy attachment that had not been flagged by a ticket. F-01 and F-02 were corrected; F-03 remains open until the retention period ends and account deletion is completed.

20. Benefits, Risks and Limitations

Benefits demonstrated

- Security: reduced unnecessary access in the tested scenarios, group-based permissions and MFA enforcement for the three department groups.
- Operations: repeatable Joiner/Mover/Leaver steps and more structured AccessDenied troubleshooting.
- Auditability: documented simulated approvals, tickets, CloudTrail evidence, access tests and retain/remove decisions.
- Cost: the lab was designed to avoid compute charges; confirm actual billing and free-tier usage in the AWS console.

Limitations and risks

- Single account and a small test population; not a production-scale governance deployment.
- Manual AWS Console workflow; no implemented JML automation.
- Approvals and user scenarios were simulated.
- Standing AdministratorAccess remains on the LabAdmins group.
- The MFA exception required an admin to enroll Bob in the tested flow.
- The cause of F-02 was not traced.
- Active Directory, Microsoft Entra ID, SSO and SailPoint were conceptual/out of scope, not hands-on integrations.
- F-03 remains open until Charlie's account is deleted after the retention period.

21. Lessons Learned

- Groups make access easier to manage consistently than individual user policy attachments.
- Least privilege means adding only the action and resource needed for the user's job.
- An applicable explicit Deny overrides an Allow.
- Role assumption requires caller-side permission and a compatible role trust policy; the role also needs its own permissions.
- For S3, bucket-level actions and object-level actions use different resource ARNs.
- CloudTrail helps identify recorded API events, and Policy Simulator helps test policy decisions under specified conditions.
- Remove old access before adding new access during a department transfer.
- Disable a leaver's sign-in promptly, remove permissions, verify access is blocked and follow the retention policy for deletion.
- Periodic reviews can catch control gaps that tickets miss.

22. Results and Conclusion

Measure	Result
Users / groups	4 users, 4 groups
Custom policies / role	5 custom policies and 1 role; AdministratorAccess is AWS-managed
Lifecycle tickets	3 of 3 completed: joiner, mover and leaver
Access/role cases	3 of 3 resolved: EC2 denied, role assumption and S3 object scope
Security-control ticket	IAM-007 closed; MFA and password settings configured and tested in the lab
Review findings	3 raised: F-01 and F-02 fixed; F-03 remains open pending account deletion after retention
Access keys	No active access keys found for the reviewed lab users

Conclusion

This project built and tested a working AWS IAM lab and documented the access lifecycle with simulated approvals and evidence. Access was organized through groups and least-privilege policies, MFA was configured for the three department groups, and temporary finance S3 access was provided through a role instead of a permanent permission for Bob. Seven tickets were documented. Three lifecycle workflows and three access/role cases were completed, and the access review found and corrected two control gaps. Charlie's account deletion remains pending after the retention period.

23. Future Improvements

- Automate Joiner/Mover/Leaver processing with a reviewed script or infrastructure-as-code workflow; use a dry-run mode and audit log before making live changes.
- Consider Terraform for repeatable infrastructure and IAM policy deployment.
- Use EventBridge-based monitoring/alerts for relevant IAM policy changes.
- Improve MFA self-enrolment while preserving a safe recovery path.
- Replace standing administrator access with time-limited, approved elevation where feasible.
- Explore SSO and identity governance tooling at scale; SailPoint was not implemented in this lab.
- Use IAM Access Analyzer and unused-access review capabilities where appropriate.

24. Cleanup Checklist

- Save screenshots, tickets and the final report before removing lab evidence.
- Empty and delete the test S3 bucket if no longer needed.
- Delete test users and the role when evidence and retention requirements permit.
- Delete Charlie's account after the documented retention period and close F-03.
- Check for access keys, leftover policies, roles and other resources created for the lab.
- Confirm billing, Free Tier usage and that no unexpected billable resources remain.

Do not delete evidence or accounts before confirming that you no longer need them for portfolio demonstration or audit retention.

25. Interview Preparation

Short project explanation

"I built a hands-on AWS IAM governance lab in one AWS account. I used groups and custom least-privilege policies, tested MFA enforcement, simulated Joiner/Mover/Leaver workflows with tickets, and investigated access failures using CloudTrail and Policy Simulator. I also provided temporary S3 access through a role and performed an access review that identified two corrected control gaps and one pending account-retention task. The lab was implemented manually through the AWS Console; automation and SailPoint integration were future scope."

Likely interview questions

- Why use IAM groups instead of attaching policies directly to each user?
- What is the difference between an IAM user, group, role and policy?
- How does least privilege apply to the policies you built?
- Why was `ec2:DescribeVolumes` denied, and what changed?
- Why did Bob's first `sts:AssumeRole` attempt fail?
- Why did `s3:GetObject` fail after role assumption succeeded?
- What is the difference between an implicit deny and an explicit deny?
- How did CloudTrail help you troubleshoot?
- What did the access review find that no ticket had flagged?
- What would you automate first in a larger environment?

Credible claims

Say	Avoid claiming
Configured IAM users, groups and policies in a lab	Implemented enterprise IAM governance in production
Tested MFA enforcement and least-privilege access	Secured every identity in a production environment
Investigated <code>AccessDenied</code> using CloudTrail and Policy Simulator	Automated incident resolution
Completed simulated JML ticket workflows manually	Integrated HR-driven automated provisioning
Documented future automation and governance ideas	Implemented SailPoint, Terraform or JML automation

Keep answers grounded in what you actually configured, tested and can explain. Screenshots should match the final written results.

Appendix A. Ticket Register

Ticket	Type	Scenario	Key evidence
IAM-001	Joiner	Alice added to Finance-Group	Group membership; finance S3 allowed; EC2 denied
IAM-002	Mover	Alice moved Finance → Support	Old group removed first; CloudWatch allowed; S3 denied
IAM-003	Leaver	Charlie's access removed	Console disabled; no group/policies; failed sign-in
IAM-004	Incident	Bob's EC2 volumes denied	CloudTrail denied event; policy fix; successful test
IAM-005	Role access	Bob assumed FinanceS3ReadRole	AssumeRole failure; caller permission added; role session works
IAM-006	Incident	S3 GetObject denied in role session	Resource ARN corrected; object read succeeds
IAM-007	Security	MFA/password standards	RequireMFA policy; password settings; MFA test evidence

Appendix B. Screenshot Evidence Checklist

- Users and groups at setup; Alice's initial state before IAM-001.
- Department group policies before custom least-privilege policies and after replacement.
- RequireMFA policy and account password policy.
- Bob blocked without MFA and permitted after MFA.
- IAM-001: Alice in Finance-Group, S3 read succeeds, EC2 denied.
- IAM-002: Alice in Support-Group, CloudWatch allowed, Finance S3 denied.
- IAM-003: Charlie console access disabled, no group/policies, failed sign-in.
- IAM-004: EC2 dashboard denied before and Volumes tile working after; CloudTrail event and policy test.
- IAM-005: role trust/permissions, failed AssumeRole event and successful role switch.
- IAM-006: GetObject AccessDenied, corrected object resource and successful object read.
- IAM-007: MFA policy, simulator denied without MFA context and allowed with MFA context.
- Credential report and user Permissions tabs for access review.
- F-01 direct policy removed; F-02 RequireMFA reattached to Developer-Group.

Final status note

The report records F-03 as open. Update it only after Charlie's account is deleted following the retention period and the deletion is verified. Do not mark the findings section as having no pending actions while F-03 remains open.